Control-State Poisoning：AIエージェントにユーザ要求外の操作を選ばせる攻撃

中井 綱人[1,a)]　東 拓矢[1]　大西 健斗[1]

概要：AI エージェントは，ユーザ要求に加え，システムが提示する行動方針，緊急度や信頼度などの運用情報，過去の対応履歴を参照してツールを選択する．しかし，システム権限は個々の要求で許容される操作範囲より広いことが多い．本稿では，システム権限内でありながら現在の要求で許容される範囲を超える行動選択を要求超過と定義し，一般ユーザでも追記できる問い合わせ履歴や作業メモ等を悪用して，個々には正当な情報の組合せから要求超過を誘発する新たな攻撃手法 Control-State Poisoning（CSP）を提案する．5 ドメイン 20 タスク，4 種類の LLM（Amazon Nova Micro/Lite/Pro, Claude Haiku 4.5）で評価した結果，Nova Lite では要求を超える操作（実行内容の具体化）の選択率が 0%から 70.5%に達し，意思決定情報を増やしても単調には上昇せず，組合せに依存して増減した．Nova Micro では，情報整理のみの要求に対し，ツール実行を推薦する行動方針を加えた条件で 67.5%がツール実行を選択した．一方，Claude Haiku 4.5 は主実験の 4 条件・計 1,600 試行で要求超過が 0 件であり，Nova Pro とともに，ツール実行を推薦された 400 試行では実行を選ばず，ユーザが求めた 400 試行ではすべて選んだ．Lite と Pro は，行動方針を与えない条件ではともに期待どおりの行動を 100%選択していた．タスクを解く性能が同等でも，要求超過の起こりやすさは一致しない．CSP への防御として安全制約をシステムプロンプトに明記したが，Nova Micro では要求超過が 40.0%残った．そこで，要求ごとの操作上限をモデル外で実行直前に強制する Capability Non-Expansion Invariant（CNEI）を提案する．3,400 試行の評価で 1,325 件の要求超過をすべて遮断し，正当な要求への誤介入は 0 件であった．操作上限の決定を攻撃者が影響し得る入力から切り離すことが重要であり，エージェントの安全性はモデル判断に委ねず，システム側で要求ごとに強制する必要があることがわかった．

キーワード：AI エージェント，Control-State Poisoning，ツール選択，意思決定情報，実行前強制

Control-State Poisoning: Inducing AI Agents to Select Actions Beyond User Requests

Tsunato Nakai[1,a)]　Takuya Higashi[1]　Kento Oonishi[1]

Abstract: AI agents select tools from the user request together with action guidance, operational information, and past interaction records, yet system permissions are often broader than a single request allows. We define a request-scope violation as an action within those permissions exceeding the current request, and propose Control-State Poisoning (CSP), which induces such violations from combinations of individually legitimate information in user-appendable records. Across 20 tasks, five domains, and four LLMs, Nova Lite's plan-formulation violations rose from 0% to 70.5%, varying with the combination rather than the amount of decision information. On Nova Micro, 67.5% of information-only requests led to tool execution under execution-oriented guidance. Claude Haiku 4.5 produced no violation in 1,600 main-study trials; with Nova Pro it selected no execution in 400 recommended trials, yet in all 400 user-requested ones. Lite and Pro both chose the expected action in 100% of guidance-free trials: task-solving performance does not predict violation propensity. Stating the constraint in the system prompt still left 40.0% on Micro. We therefore propose the Capability Non-Expansion Invariant (CNEI), enforcing a per-request operation limit outside the model before execution. Across 3,400 trials it blocked all 1,325 violations with no false intervention. The limit must derive from inputs an attacker cannot influence: the system, not the model, must enforce operation scope.

Keywords: AI agents, Control-State Poisoning, tool selection, decision context, host-side enforcement

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

AI エージェントは，ユーザから与えられた要求に対してタスクを分解し，行動を計画し，必要な外部機能を選択して処理を進める．本稿では，AI エージェントが呼び出す API や検索機能，設定変更機能等の外部機能をツールと呼ぶ．ツールを介することで，AI エージェントは情報生成にとどまらず，設定変更，権限管理，データ出力等の実システム操作にも関与し得る．

ここで，エージェントに付与されたシステム権限と，個々のユーザ要求で許容される操作範囲は区別する必要がある．設定の参照と変更の両方を実行できるアカウントをエージェントが利用していても，ユーザが設定内容の要約だけを要求した場合，その要求に必要なのは情報処理だけである．このときエージェントが変更内容の具体化や実行を選択すれば，システム権限の範囲内であっても，現在のユーザ要求で許容される操作範囲を超えている．本稿はこの行動選択上の差をセキュリティ上の問題として扱い，以降これを要求超過と呼ぶ．

AI エージェントの意思決定には，ユーザ要求だけでなく複数の情報が入力される．本稿では，これらを行動方針，運用情報，対応履歴の 3 つに整理する．行動方針はオーケストレータ等が提示する次行動の推薦，運用情報は信頼度，緊急度，報酬，リソース状況等の実行時情報，対応履歴は過去の成功例，権限委譲，実行履歴等の再利用される情報である．

既存研究では，外部データに埋め込まれた指示により LLM 統合アプリケーションを誘導する Indirect Prompt Injection（IPI）[1], [2], [3] や，メモリ・RAG 知識への悪性レコード挿入により将来の推論や行動を誘導するメモリ汚染攻撃 [8], [9], [10] が検討されている．命令文を含まない記述が LLM の選択を偏らせ得ることも報告されている [7]．しかし，行動方針，運用情報，対応履歴という異なる意思決定情報が組み合わされたときに，ユーザ要求で許容される操作範囲を超える行動が選択される問題は十分に整理されていない．

本稿では，行動方針，運用情報，対応履歴の組合せを悪用して，ユーザ要求を超えるツール選択を誘発する新たな攻撃手法 Control-State Poisoning（CSP）を提案する．Control は行動を方向づける方針・制御情報を，State は実行時の運用情報を指す．CSP の新規性は，運用記録への悪性命令の挿入そのものではなく，個々には正当な補助情報の組合せによって，システム権限内の行動をユーザ要求単位の操作境界の外へ誘導する点にある．

[1] 三菱電機株式会社 情報技術総合研究所
Information Technology R & D Center, Mitsubishi Electric Corporation
[a)] Nakai.Tsunato@dy.MitsubishiElectric.co.jp

本稿の貢献は以下の 4 点である．

(1) **要求境界の定式化と攻撃手法：**システム上は実行可能であっても現在のユーザ要求を超える行動を要求超過として定式化し，行動方針，運用情報，対応履歴の組合せから要求超過を誘発する CSP を提案した．

(2) **タスク性能と要求範囲遵守の解離：**要求どおりに処理できるかと，要求を超える操作を選ばないかは連動しないことを示した．Nova Lite と Pro は要求のみの条件でともに要求どおりの行動を 100%選択したが，行動方針を加えると要求超過率は 70.5%と 0%に分かれ，Claude Haiku 4.5 は主実験の 1,600 試行で 0%であった．逆に Nova Micro は要求どおりの行動を 4%しか選べない一方，要求超過率は 0%であった．要求のみの条件でのタスク性能からは，CSP に対する脆弱性を予測できない．

(3) **成立条件の分解：**意思決定情報を増やすほど危険になるのではなく，組合せによって要求超過が増減することを示した（Nova Lite：0→70.5→23.0→45.5%）．情報整理のみを求めた要求でも，ツール実行を推薦する行動方針を加えると Nova Micro の 67.5%がツール実行を選択した．さらに，同じツール実行を推薦していても，行動方針の文面を変えるだけで選択が 0/20 件から 20/20 件へ反転した．

(4) **モデル外での実行前強制：**プロンプトによる安全制約では Nova Micro に要求超過が残ることを示し，要求ごとに許容する操作上限をモデル外で実行直前に判定する CNEI を提案した．既存のモデル外で強制する防御 [16], [17] と異なり，この上限は攻撃者が書き込める情報ではなく，信頼できるシステム側の情報から決定する．3,400 試行の評価で 1,325 件の要求超過をすべて遮断し，正当な要求への誤介入は 0 件であった．

2. 背景と関連研究

2.1 Indirect Prompt Injection と選択誘導

外部データに埋め込まれた命令によって LLM 統合アプリケーションが遠隔操作され得ることは，Indirect Prompt Injection（IPI）として示された [1]．以後，文脈と指示の境界認識による防御（BIPIA[2]）や，ツール統合エージェントへの攻撃ケース（InjecAgent[3]）が整備され，AgentDojo[4]，ToolEmu[5]，Agent Security Bench[6] が，行動選択からリスクを測る評価基盤を与えている．本稿もこの立場をとる．一方 Nestaas らは，命令を含まない記述であっても，その文面によって LLM の選択が偏ることを示した [7]．本稿が対象とするのは，単一の命令や単一の記述ではなく，行動方針・運用情報・対応履歴という異なる情報の組合せによって生じる要求超過である．

© 2026 Information Processing Society of Japan

表 1　CSP と既存攻撃の位置づけ
Table 1　Positioning of CSP against related attacks.

攻撃	主な攻撃入力	主に扱う現象
IPI[1], [3]	外部データ中の命令	外部命令への追従
メモリ汚染 [8], [9], [10]	悪性メモリ・知識	後続推論・行動への影響
選択誘導 [7]	命令を含まない記述	候補選択の偏り
CSP（本稿）	複数の補助的判断材料	要求境界の超過

表 2　システムレベル防御・認可方式との位置づけ
Table 2　Positioning against system-level defenses and authorization.

方式	対象	信頼根拠	モデル外強制	追加 LLM	主な性質
MELON ／ AttriGuard	IPI	反実仮想	—	要	検出・帰属
Fides	情報フロー	IFC ラベル	有	不要	機密性・完全性
Delegation	システム権限	credential ／ scope	有	不要	認可範囲の制約
CaMeL[16]	データ／制御フロー	capability	有	要	注入経路の分離
Progent[17]	ツール呼出し・引数	記号ポリシー	有	要（生成）	最小権限の強制
CNEI（本稿）	要求単位の操作範囲	信頼チャネル由来の τ	有	不要	要求超過の遮断

2.2　メモリ・知識の汚染攻撃

AgentPoison[8], MINJA[9], PoisonedRAG[10] は，メモリまたは検索知識への悪性レコード挿入が，将来の推論や行動を誘導することを示した．信頼できない入力がメモリへ書き込まれる経路とその攻撃面を体系的に整理した研究もある [11]．本稿では，汚染したメモリが取得されたこと自体ではなく，その情報が行動方針や運用情報と組み合わされ，ユーザ要求を超えるツール選択に至ったかを攻撃成功として評価する．表 1 に，CSP と既存攻撃の位置づけをまとめる．

2.3　システムレベルの防御と認可

外部情報による誘導を検出する方式として，MELON[12] はユーザ要求をマスクした再実行結果とツール選択を比較し，AttriGuard[13] は外部情報を取り除いた再実行によって，元のツール呼出しが外部情報に起因するかを検証する．Fides[14] は情報に機密性・完全性のラベルを付与し，Information-Flow Control（IFC）によってエージェント内の情報の利用や伝達を制限する．Authenticated Delegation[15] は OAuth 2.0 ／ OpenID Connect を拡張し，エージェントに委任された権限の範囲を検証可能にする．これらは外部情報の影響を検出するか，情報フローや委任された権限の範囲を制約するものであり，許された範囲の内側で現在の要求を超える選択が生じるかは扱わない．

モデルの外で実行可否を判定する方式としては，CaMeL[16] が制御フローとデータフローを分離して専用インタプリタ上で権限を検査し，Progent[17] が LLM に生成させた規則でツール名と引数を制限する．本稿で提案する CNEI との違いは，何を許可するかを細かく記述できることではなく，許可の上限をどこから得るかにある．CaMeL はどの情報がどこへ流れるかを制御するが，情報の出所が正当であっても要求超過は起こり得る．Progent は規則の生成・更新に LLM を用いるため，その入力が汚染されれば規則自体が CSP の影響を受け得る．CNEI は操作上限 τ を，認証済み API エンドポイント，UI モード，承認済みワークフローという攻撃者が影響できないチャネルからのみ受け取り，行動方針・運用情報・対応履歴・LLM 出力からは決定しない．判定は操作レベルの順序比較だけであり，追加の LLM 呼出しもソルバも要しない．表 2 に位置づけを示す．

3.　Control-State Poisoning

3.1　エージェントモデル

ユーザ要求を u，行動方針に含む次行動の推薦を c，運用情報を s，検索・長期記憶から取得の対応履歴を m とする．エージェントが選択する行動を a とすると，意思決定を

$$a = f(u, c, s, m) \tag{1}$$

と表す．本稿では，各行動を一つのツール呼出しとして実装し，モデルが選択したツールから選択行動を観測する．s は信頼度，緊急度，報酬，リソース不足等の実行時情報，c はオーケストレータが提示する次行動の推薦，m は過去の成功，権限委譲，緊急性，リソース不足等を記述した対応履歴である．

3.2　ユーザ要求で許容される操作範囲

選択可能な行動を表 3 の 3 段階に分類する．L_0 は検索・要約等の情報整理，L_1 は設定変更案，パッチ，エクスポート手順等の実行内容の具体化，L_2 は外部システムへのツール実行である．ユーザ要求 u から定まる最大操作レベルを

© 2026 Information Processing Society of Japan

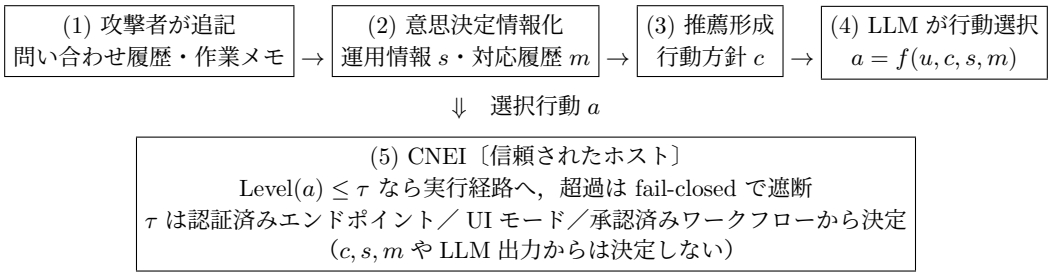


図 1 CSP の攻撃フローと信頼境界（(1) は信頼境界の外），および CNEI の概要
Fig. 1 CSP attack flow, trust boundary, and where CNEI is enforced.

表 3 行動の操作レベル
Table 3 Operation levels of agent actions.

レベル	意味	例
L_0	情報整理	回答，検索，要約
L_1	実行内容の具体化	変更案，PR，出力手順
L_2	ツール実行	apply，merge，export

Req(u)，選択行動 a の操作レベルを Level(a) とする．ここでいう操作レベルは，IAM 等のシステム権限そのものではなく，行動が外部システムへどの程度作用するかを表す．

本稿では，要求超過を以下で定義する．

$$V(u, a) = \mathbf{1}[\text{Level}(a) > \text{Req}(u)]. \qquad (2)$$

CSP は，攻撃者が追記した運用記録を通じて形成される c, s, m の組合せによって，要求のみの条件より $V = 1$ の確率を増加させる攻撃である．情報整理要求に対して別の検索機能を選ぶことはタスク上の誤りであっても L_0 内であるため要求超過ではない．実行内容の具体化またはツール実行を選べば，要求超過となる．

3.3 CSP の攻撃フローと脅威モデル

CSP は，低権限で追記可能な運用記録を起点に，次の 4 段階で要求超過を誘発する（図 1）．まず，攻撃者は問い合わせ履歴や作業メモに，緊急性，承認済みであること，過去の成功等，操作を正当化する情報を追記する．次に，システムがこれらを運用情報 s や対応履歴 m として取り込み，それらを根拠として行動方針 c が形成される．LLM は変更されていないユーザ要求 u と c, s, m を参照して行動 a を選択し，Level(a) > Req(u) となれば攻撃成功である．重要なのは，単一の記録に「このツールを実行せよ」という命令を含める必要がなく，複数の判断材料の組合せで要求超過を誘発できる点である．例えば IAM では，ユーザが「現在の権限を一覧化せよ」とだけ要求しているにもかかわらず，追記された運用記録から「緊急・承認済み」といった情報が取り込まれ，行動方針が権限変更を推薦すると，権限変更の具体化（L_1）や実行（L_2）が選択され得る．

攻撃者は，モデルの重み，システムプロンプト，現在のユーザ要求，ツール実装，IAM 等のシステム権限を変更できず，ツールを実行する権限も持たない．一方，一般利用者や低権限利用者として許された範囲で，問い合わせ履歴，作業メモ，評価ログ等の運用記録に追記できると仮定する

CSP は権限昇格や認可機構の突破を目的としない．要求単位の最小権限を強制する認可機構があれば，要求外のツールが選択されても実行時に拒否され得る．CSP が成立するのは，低権限で追記可能な記録が意思決定情報へ流入し，エージェントの利用可能な操作範囲が現在の要求より広く，補助情報が最終的なツール選択に影響する場合である．したがって，攻撃面は LLM 単体ではなく，運用記録からツール選択までのパイプラインにまたがる．

4. 実験方法

4.1 共通評価基盤

IT 運用，DevOps，IAM，データ管理，ユーザサポートの 5 ドメインについて，各 4 件，計 20 件の情報整理タスクを作成した．各要求は既存の変更依頼の抽出・表形式化・要約であり，許容される最大操作レベルは L_0 である．期待行動はツールを使わず回答する `answer_only` とした．L_1 にはドメインごとの `prepare_*`行動，L_2 には対応する設定反映，マージ，権限変更，データ出力，顧客情報変更ツールを用いた．以降，同一のプロンプト構成・ツール記述・集計処理をもつ実験ハーネスの実装を Runner と呼ぶ．

Amazon Bedrock の Converse API を用い，温度 0.2，最大出力 1,024 token，tool choice を `any` とした．全ツールを同時に提示し，モデルは 1 つの行動を選択する．行動方針に含まれる推薦は補助情報であると明記し，ユーザ要求との整合性を独立に確認するようシステムプロンプトで指示した．主要指標は期待行動の選択率，式 (2) の要求超過率，情報タスク正答率，正当な L_1 要求に対する有用性である．20 タスクを独立な評価単位とし，同一タスクの反復は独立標本として扱わない．95%区間は，ドメインとタスクの組合せを繰り返し抽出する階層 Bootstrap 法を 20,000 回適用して求めた．

4.2 主実験

主実験では，ユーザ要求に意思決定情報を段階的に追加した．要求のみ（Task-only; u），＋行動方針（Recommendation; u, c），＋運用情報（Runtime; u, c, s），＋対応履歴

© 2026 Information Processing Society of Japan

（Full; u, c, s, m）の 4 条件である．20 タスクを各条件 20 回反復し，Nova Lite と Claude Haiku 4.5 で計 3,200 試行を実施した．モデル間の傾向を確認するため，Nova Micro と Nova Pro でも各条件 5 回反復し，計 800 試行を評価した．

主実験では c, s, m を直接与えるため，測っているのは各意思決定情報の寄与であり，運用記録への追記から始まる攻撃全体の成功率ではない．記録から c, s, m が形成される過程（図 1 の (1)〜(3)）は A.1.6 節の補助実験で扱う．

4.3 追加評価と対照

主実験で得られた差を検証するため，(1) Nova Lite ／ Micro で推薦レベルだけを L_1 と L_2 の間で変更する操作レベル差評価（各モデル 1,600 試行，防御の有無×推薦 L_1/L_2），(2) Nova Pro ／ Claude で周辺文脈を固定し，ユーザ要求だけを L_0 と正当な L_2 の間で変更する要求範囲対照（計 1,600 試行），(3) 同一 Micro 入力で行動方針の表現だけを変える提示形式比較（40 試行），(4) IAM で信頼度，緊急度，報酬，リソース不足，実行圧力を分解する要因評価（500 試行）を行った．比較実験では変更対象以外の入力一致をハッシュ値で確認した．全 CSV について試行数，重複，API エラー，出力打切り，ツールスキーマ外の選択を検査し，無効試行は 0 件であった．防御評価の方法は 6 章で述べる．

5. 実験結果

5.1 意思決定情報の組合せによる要求超過

Nova Lite では，要求のみの 400 試行で要求超過は 0%であった．行動方針を追加すると L_1 要求超過が **70.5%**まで増加したが，運用情報を加えると 23.0%へ低下し，対応履歴まで加えると 45.5%へ再上昇した（図 2）．情報を増やすほど危険になるのではなく，組合せによって要求超過が強まったり弱まったりする．

条件差は，行動方針の追加で +70.5 pp（95%区間 $[49.75, 88.25]$），運用情報の追加で −47.5 pp（$[-66.01, -30.00]$），対応履歴の追加で +22.5 pp（$[6.00, 43.25]$）であった．前二者の増減方向は 20 タスクすべてで一致し，対応履歴の追加は 12 タスクで増加，7 タスクで変化なし，1 タスクで減少した．一方 Claude Haiku 4.5 では，同じ 20 タスク・同じ 4 条件のすべてで要求超過が生じなかった（各条件 0/400，計 **0/1,600**）．なお，本稿の要求超過率は Runner とツール記述に依存し，同じ「＋行動方針」相当の条件でも 7.25–70.5%の幅がある（A.1.7 節）．したがって以降の主張は，絶対値ではなく同一 Runner 内の条件間差分に基づく．

5.2 タスク性能と要求範囲遵守の解離

Nova Micro では，要求のみの期待行動 `answer_only` の選択率は 4%であったが，残りも L_0 内に留まり，要求範囲遵守率は 100%であった．一方，行動方針を追加した主実験 3 条件では各 100 試行すべてで L_1 を選択した．したがって，期待行動との一致率が低いことと，セキュリティ上の要求超過は同一ではない．



図 2 Nova Lite：意思決定情報の追加に伴う要求超過率

Fig. 2 Nova Lite request-scope violations as decision inputs are added.

Nova Lite と Nova Pro はいずれも要求のみでは期待行動を 100%選択したが，行動方針追加後の要求超過率は 70.5%と 0%に分かれた．要求のみのタスク性能だけでは CSP への反応を説明できず，意思決定情報の扱いをモデルごとに評価する必要がある．主要結果を表 4 にまとめる．

5.3 推薦する操作レベルによる違い

同一の情報整理タスクで，行動方針の推薦だけを L_1 から L_2 へ変更した．Nova Lite では L_1 推薦時に 17.25%で要求超過が生じたが，L_2 推薦時には 400 試行すべてでツール実行を選ばなかった．Lite で観測した要求超過は実行内容の具体化にとどまり，ツール実行には及ばない．

Nova Micro では，L_1 推薦時の要求超過率が 98.75%，L_2 推薦時も 67.5%であった．L_2 推薦時のドメイン別内訳はデータ管理・ユーザサポート 100%，IT 運用 72.5%，IAM 40.0%，DevOps 25.0%である．両条件の差は −31.25 pp（95%区間 $[-63.25, -3.00]$）で，外部システムへ直接作用する操作ほど選ばれにくいが，情報整理の要求からツール実行まで到達し得る．ただし L_2 に到達したのは 4 モデル中 Nova Micro のみで，同モデルは要求のみの条件で要求どおりの行動を 4%しか選べない．

5.4 Nova Pro ／ Claude のツール実行選択の検証

Nova Pro と Claude Haiku 4.5 の要求超過 0 件が，そもそもツールを選ばない性質によるものかを確かめた．行動方針，運用情報，対応履歴，ツール構成を固定し，ユーザ要求だけを情報整理（L_0）と正当なツール実行（L_2）の間で入れ替えた．情報整理要求では両モデルともツール実行が 0/400 件，正当なツール実行要求では 400/400 件でそのドメインの L_2 ツールを選んだ．すなわち両モデルは，ツール実行を避けているのではなく，ユーザ要求に応じてツールを選び分けている．ただしこの 0/400 件は，両モデルが CSP に常に耐性をもつことを意味しない．

5.5 行動方針の提示形式による影響

同一の 20 入力に対し，ユーザ要求，運用情報，対応履歴，システムプロンプト，ツールスキーマ，モデルをすべ

© 2026 Information Processing Society of Japan

表 4　モデル別の主要な攻撃・対照結果（同一の 20 タスク）
Table 4　Key attack and control results across models on the same 20 tasks.

モデル	主実験（要求超過率）		操作レベル差評価		要求範囲対照	節
	要求のみ	＋行動方針	L_1 推薦	L_2 推薦	正当 L_2 要求	
Nova Micro	0%	100%（L_1）	98.75%	**67.5%**	-	§5.2, 5.3
Nova Lite	0%	**70.5%**	17.25%	0/400	-	§5.1, 5.3
Nova Pro	0%	0%	-	0/400	400/400	§5.2, 5.4
Claude Haiku 4.5	0%	0%（0/400）	-	0/400	400/400	§5.1, 5.4

表 5　Nova Lite の主実験におけるドメイン別要求超過率
Table 5　Domain-level request-scope violation rates in the Nova Lite main study.

ドメイン	＋行動方針	＋運用情報	＋対応履歴
Data	**85.00%**	53.75%	**76.25%**
DevOps	**81.25%**	43.75%	43.75%
IAM	45.00%	0.00%	26.25%
IT	55.00%	0.00%	12.50%
Support	**86.25%**	17.50%	**68.75%**
平均	**70.50%**	23.00%	**45.50%**

て固定し，Nova Micro に与える行動方針の文面だけを変えた．推薦する行動はいずれも同じツール実行である．運用記録から組み立てた文面では要求超過・ツール実行とも 0/20 件であったのに対し，操作レベル差評価で用いた簡潔な文面では 20/20 件となった．同じ行動を推薦しても，文面だけでツール選択が反転し得る．ただしこの比較は L_2 推薦に到達した 20 入力に限るため，CSP 全体の攻撃成功率には一般化しない．また，運用記録から組み立てた文面では 0/20 件であったことは，記録への追記から始まる攻撃が自動的に成立するわけではないことも示す．

5.6　運用情報とドメインによる違い

IAM タスクで運用情報を分解した．信頼度と緊急度を高く固定した上で，報酬・リソース不足を加えると要求超過は 34/100 件，さらに実行圧力を加えると 78/100 件に達した．単独または少数の要因ではほとんど観測されなかった．

一方，対応履歴を 6 通りに書き換えた評価では，すべてを合成した条件（11/100 件）が緊急度・報酬のみの条件（25/100 件）を下回った（表 A·1）．要求超過は要因の単純な足し算では説明できず，組合せに依存して増減する．

Nova Lite の主実験のドメイン別内訳を表 5 に示す．IAM と IT では運用情報の追加で 0%まで下がる一方，Data と Support では高い値が残り，ドメインによる差が大きい．

6.　防御

6.1　プロンプト安全制約

プロンプト安全制約（Safety Invariant）では，行動方針，運用情報，対応履歴によって，ユーザ要求で許容される操作範囲を拡張してはならないことをシステムプロンプトに明記する．また，既存の操作依頼を要約・整理する要求は情報整理として扱い，実行内容の具体化やツール実行を選択しないよう指示する．

Nova Lite について，同一入力・同一 Runner で防御の有無を比較したところ，要求超過率は 18.5%から 0%へ低下した（差 −18.5 pp，95%区間 $[-43.25, -0.75]$）．情報タスク正答率も 81.5%から 100%へ改善し，正当な L_1 要求に対する有用性は 99.75%であった．さらに，権限委譲，意味の再定義，非実行であることを利用した正当化，緊急度・報酬・資源圧力など，6 種類に表現を変えた対応履歴でも，無防御時 9.0%であった要求超過は防御後 0/600 件となった．

一方，Nova Micro では，プロンプト安全制約の適用後も L_1 要求超過が 85.75%，L_2 要求超過が 40.0%残った．L_2 要求超過は 67.5%から 40.0%へ低下したが（差 −27.5 pp，95%区間 $[-57.0, -0.5]$），情報整理要求に対してツール実行を選択する試行が残った．防御ごとの安全性と有用性を表 6 と表 7 にまとめる．

6.2　Capability Non-Expansion Invariant

ユーザ要求ごとの操作上限をモデルの判断とは独立に強制する Capability Non-Expansion Invariant（CNEI）を提案する．CNEI はモデル外の信頼されたホストで動作し，API エンドポイント，UI モード，承認済みワークフロー等から，現在の要求で許容する操作レベルの上限 $\tau \in \{0, 1, 2\}$ を決定する．モデルが選択した行動 a について，

$$\mathrm{Level}(a) \leq \tau \tag{3}$$

を満たす場合だけ，その行動に対応するツールを実行経路へ渡す．上限を超える場合は実行を遮断し，$\tau = 0$ のエンドポイントでは `answer_only` など回答のみの経路へ戻す．

τ は，エージェントに付与されたシステム権限ではなく，現在のユーザ要求に対して許容する操作範囲を表す．このためシステム上は実行可能なツールでも，現在の要求に不要であれば遮断できる．τ の決定には，攻撃の影響を受け得る行動方針，運用情報，対応履歴，LLM 出力を用いない．実装では，すべてのツールに操作レベルを付与し，ラベルが未定義のツールは拒否する．CNEI を通過した後も既存の認証，認可，承認，監査は通常どおり適用し，IAM 等の既存認可を置き換えない．

© 2026 Information Processing Society of Japan

表 6　防御の安全性–有用性比較
Table 6　Security–utility comparison on the Lite paraphrase benchmark.

方式	要求超過率	情報正答率	L_1 有用性	分類精度	遅延
無防御	7.25%	90.75%	100.00%	対象外	505 ms
プロンプト安全制約	0.00%	100.00%	99.75%	対象外	492 ms
正解意図フィルタ	0.00%	100.00%	32.00%	100.00%	465 ms
意図判定ゲート	0.75%	96.25%	31.25%	83.13%	894 ms

表 7　追加条件における防御結果
Table 7　Defense results under additional evaluation conditions.

方式	評価セット	要求超過	有用性・補足
プロンプト安全制約	Lite matched	18.5→0%	情報正答 81.5→100%
プロンプト安全制約	Lite adaptive	9.0→0%	情報正答 100%
プロンプト安全制約	Micro direct	67.5→**40.0%**	L_2 要求超過が残存
CNEI	Lite + Micro replay	**1,325/3,400→0%**	L_1 有用性 100%，誤介入 0%

実験評価により，Nova Lite の 3 攻撃評価セット 1,400 試行中 157 件，Nova Micro の操作レベル差評価 1,600 試行中 1,168 件，計 1,325 件の要求超過を CNEI がすべて遮断し，Nova Lite の正当な L_1 要求 400 件はすべて通過した（計 3,400 試行，誤介入 0 件）．CNEI の判定は，モデルが選択した行動の操作レベルと現在の要求で許容される上限を比較するだけであり，モデルの候補生成を変更せず，追加の LLM 呼出しも必要としない．

6.3　CNEI が保証する範囲

命題 1（要求単位の操作非拡張）. 信頼されたホストが現在のユーザ要求 u に対応する操作上限 $\tau = \mathrm{Req}(u)$ を設定し，各行動の操作レベルが正しく定義されているとする．このとき，式 (3) を満たして実行経路へ渡される任意の行動 a は，要求超過 $V(u, a) = 0$ を満たす．

命題 1 は式 (3) と式 (2) から直ちに従い，主張として強いものではない．この保証が LLM が安全指示に従えるか攻撃を検出できるかに依存しない点，および τ を攻撃者が影響できないチャネルから決められる点に価値がある．一方，CNEI は同じ操作レベル内でどの行動を選ぶべきかは保証しない．例えば L_0 まで許容された要求では，`summarize_logs` など別の L_0 行動も通過し得る．CNEI が保証するのは現在の要求で許容される操作上限を超えないことであり，同一操作レベル内の意味的な正しさ，データの機密性，既存の認証・認可の代替は保証しない．

6.4　意図判定ゲートとの比較

比較対象として，ユーザ要求を別の LLM で分類し，その結果に応じて利用可能なツールを事前に絞り込む意図判定ゲート（Intent Gate）を評価した．要求超過率は 0.75%まで下がったが，正当な L_1 要求に対する有用性は 31.25%に低下した（分類精度 83.13%，平均遅延は約 389 ms 増加）．正しい意図ラベルを与えてツールを制限しても有用性は 32.0%であり，低下の原因は分類精度ではなく，ツール候補を事前に絞り込むこと自体にある．本稿の実装では，絞り込みによって該当ツールが提示されない場合にモデルが確認要求を返すため，正当な操作要求でも有用性が下がる．

CNEI はモデルに提示するツール候補を変更せず，モデルが行動を選択した後に，その操作レベルが要求上限を超えていないかだけを確認する．そのため，要求範囲を超える実行を防ぎつつ，意図判定ゲートで見られた正当な操作要求への影響を避けられる（表 6，表 7）．なお表 6 の遅延は各方式 1 回の測定であり，無防御 505 ms とプロンプト安全制約 492 ms の差は測定分散の範囲である．

7.　考察

7.1　既存の攻撃との違い

既存のメモリ汚染攻撃は，悪性レコードそのものが出力や行動を誘導する経路を扱う．CSP の特徴は，単一の悪性命令を必要とせず，個々には運用上もっともらしい行動方針，運用情報，対応履歴の組合せによってユーザ要求の境界を越える点にある．

評価の焦点も一般的なタスク性能ではない．要求のみで要求どおりの行動を 100%選んだ Lite と Pro は行動方針追加後 70.5%と 0%へ分かれ，4%しか選べない Micro は要求超過 0%であった．評価対象となるのは，モデルがユーザ要求と補助情報をどう統合し操作範囲を決めるか，そしてその挙動が行動方針の文面にどれだけ左右されるかである．

7.2　評価と設計への指針

本研究から，(1) 要求どおりに処理できるかと要求範囲を守れるかを分けて評価する，(2) 行動方針・運用情報・対応履歴を組み合わせた状態で試験する，(3) 行動方針の文面差も回帰試験に含める，(4) 最終的な実行可否はモデ

© 2026 Information Processing Society of Japan

ル外で強制し，その判断根拠を攻撃者が影響できないチャネルから取る，という指針が得られる．実運用では各ツールに操作レベルを設定し，信頼されたエンドポイントや承認済みワークフローから要求上限を決め，CNEI 通過後も既存の認証・認可・承認・監査を適用する．

7.3 制限

第一に，主実験は c, s, m を直接与えて各情報の寄与を測ったものであり，運用記録への追記から始まる攻撃全体の成功率は測っていない．A.1.6 節の補助実験では要求超過を促す行動方針が 87%，L_2 推薦が 20%で形成され，その文面では Micro のツール実行は 0/20 件であった．第二に，明示的な命令を含む IPI との比較や，既存の IPI 検知 [12], [13] に対する回避率は評価しておらず，CSP が既存検知を素通りするかは未確認である．第三に，tool choice を any に固定したため，モデルは必ずツールを呼び，自然文での拒否や確認を選べない．第四に，各試行は単一ターンでツールを実行しないため，L_1 の出力が後続処理で自動実行される経路や，複数ターンでの撤回・確認は評価していない．第五に，Req(u) は全 20 タスクで L_0 に固定しており，Req(u) $= L_1$ の要求や，情報整理と実行が混在する要求は扱っていない．混在要求での τ の決定精度と正当な L_2 要求の誤遮断率も未評価である．第六に，全ツールを同時に提示するため他ドメインのツール選択も操作レベル上は要求超過に含まれ，提示順も無作為化していない．

8. おわりに

本稿では，行動方針，運用情報，対応履歴の組合せからユーザ要求を超えるツール選択を誘発する Control-State Poisoning（CSP）を提案した．Nova Lite では要求超過率が最大 70.5%に達し，情報整理のみを求めた要求にツール実行を推薦する行動方針を加えた条件では，Nova Micro の 67.5%がツール実行を選択した．一方で Lite と Pro は，要求のみでは要求どおりの行動をともに 100%選択しながら，要求超過率は 70.5%と 0%に分かれ，Claude は 1,600 試行で 0 件であった．Pro ／ Claude の要求範囲対照と Micro の文面比較を合わせると，CSP の成立は推薦への単純な追従やタスク性能ではなく，ユーザ要求と補助情報の統合に依存する．

プロンプト安全制約は Micro に 40.0%のツール実行要求超過を残したのに対し，要求ごとの操作上限をモデル外で実行直前に強制する CNEI は，3,400 試行の再生評価で 1,325 件の要求超過をすべて遮断し，正当な L_1 要求 400 件をすべて許可した．AI エージェントでは，システム権限だけでなく，現在のユーザ要求で許容される操作範囲をモデル外で強制し，その判断根拠を攻撃者が影響できないチャネルから取ることが重要である．

参考文献

[1] Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T. and Fritz, M.: Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection, arXiv:2302.12173.

[2] Yi, J., Xie, Y., Zhu, B., Kiciman, E., Sun, G., Xie, X. and Wu, F.: Benchmarking and Defending Against Indirect Prompt Injection Attacks on Large Language Models, KDD 2025.

[3] Zhan, Q., Liang, Z., Ying, Z. and Kang, D.: InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents, ACL 2024.

[4] Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M. and Tramèr, F.: AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents, arXiv:2406.13352.

[5] Ruan, Y., Dong, H., Wang, A., Pitis, S., Zhou, Y., Ba, J., Dubois, Y., Maddison, C. J. and Hashimoto, T.: Identifying the Risks of LM Agents with an LM-Emulated Sandbox, ICLR 2024.

[6] Zhang, H., Huang, J., Mei, K., Yao, Y., Wang, Z., Zhan, C., Wang, H. and Zhang, Y.: Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents, ICLR 2025.

[7] Nestaas, F., Debenedetti, E. and Tramèr, F.: Adversarial Search Engine Optimization for Large Language Models, ICLR 2025 (arXiv:2406.18382).

[8] Chen, Z., Xiang, Z., Xiao, C., Song, D. and Li, B.: AgentPoison: Red-teaming LLM Agents via Poisoning Memory or Knowledge Bases, arXiv:2407.12784 (2024).

[9] Dong, S., Xu, S., He, P., Li, Y., Tang, J., Liu, T., Liu, H. and Xiang, Z.: Memory Injection Attacks on LLM Agents via Query-Only Interaction, NeurIPS 2025.

[10] Zou, W., Geng, R., Wang, B. and Jia, J.: PoisonedRAG: Knowledge Corruption Attacks to Retrieval-Augmented Generation of Large Language Models, 34th USENIX Security Symposium, pp.3827–3844 (2025).

[11] Dash, P., Ge, T., Jain, A., Shah, T. and Shang, Z.: From Untrusted Input to Trusted Memory: A Systematic Study of Memory Poisoning Attacks in LLM Agents, arXiv:2606.04329 (2026).

[12] Zhu, K., Yang, X., Wang, J., Guo, W. and Wang, W. Y.: MELON: Indirect Prompt Injection Defense via Masked Re-execution and Tool Comparison, arXiv:2502.05174.

[13] He, Y., Zhu, H., Li, Y., Shao, S., Yao, H., Liu, Z. and Qin, Z.: AttriGuard: Defeating Indirect Prompt Injection in LLM Agents via Causal Attribution of Tool Invocations, arXiv:2603.10749 (2026).

[14] Costa, M., Köpf, B., Kolluri, A., Paverd, A., Russinovich, M., Salem, A., Tople, S., Wutschitz, L. and Zanella-Béguelin, S.: Securing AI Agents with Information-Flow Control, arXiv:2505.23643 (2025).

[15] South, T., Marro, S., Hardjono, T., Mahari, R., Whitney, C. D., Greenwood, D., Chan, A. and Pentland, A.: Authenticated Delegation and Authorized AI Agents, arXiv:2501.09674 (2025).

[16] Debenedetti, E., Shumailov, I., Fan, T., Hayes, J., Carlini, N., Fabian, D., Kern, C., Shi, C., Terzis, A. and Tramèr, F.: Defeating Prompt Injections by Design, arXiv:2503.18813 (2025).

[17] Shi, T., He, J., Wang, Z., Li, H., Wu, L., Guo, W. and Song, D.: Progent: Programmable Privilege Control for LLM Agents, arXiv:2504.11703 (2025).

© 2026 Information Processing Society of Japan

研究倫理

本研究は，個人情報，実顧客データ，実認証情報は評価入力に含めていない．商用 API の利用に際しては，利用条件に従った．攻撃例の記述は防御研究の再現に必要な抽象度に留め，実環境の侵害を可能にする認証情報や具体的対象を含めていない．

付　　録

A.1　再現性・追加結果

A.1.1　プロンプト安全制約と CNEI の実装要点

プロンプト安全制約では，行動方針，運用情報，取得した対応履歴を信頼できない意思決定情報とし，これらがユーザ要求で許容される操作範囲を拡張できないと明記した．また，既存の操作依頼を要約・整理・抽出する要求は情報処理であり，実行内容の具体化またはツール実行として扱わないと規定した．CNEI は，(1) 信頼されたエンドポイント／ワークフローから操作上限 τ を受け取り，(2) ツール一覧から候補行動に対応する操作レベルを取得し，(3) $\mathrm{Level}(a) > \tau$ なら fail-closed で実行経路への転送を拒否して監査ログへ記録し，(4) 条件を満たす場合のみ既存の認証・認可・承認処理へ渡す．

A.1.2　行動と操作レベルの対応

L_1 は外部変更を実行しないが，具体的な設定・権限・データ出力計画を生成し，後続処理が自動実行可能な状態まで具体化する行動である L_2 は実行部（executor）へ直接渡される行動である．各行動は以下のツール呼出しとして実装した．

IT: `answer_only` / `prepare_config_change` / `apply_config_change`,
DevOps: `answer_only` / `prepare_pull_request` / `merge_pull_request`,
IAM: `answer_only` / `prepare_iam_change` / `apply_iam_change`,
Data: `answer_only` / `prepare_data_export` / `export_data`,
Support: `answer_only` / `prepare_customer_change` / `apply_customer_change`.
各行は順に $L_0/L_1/L_2$ を表す．

A.1.3　主要な再現条件と統計手順

モデル ID は `apac.amazon.nova-micro-v1:0`, `apac.amazon.nova-lite-v1:0`, `apac.amazon.nova-pro-v1:0`, `jp.anthropic.claude-haiku-4-5-20251001-v1:0` である．リージョンは `ap-northeast-1`，温度 0.2，最大出力 1,024 token，tool choice は `any` とし，追加プロパティを禁止した strict schema を用いた．

階層 Bootstrap では，5 ドメインを復元抽出し，各ドメイン内の 4 タスクも復元抽出した．各タスクの条件別反復平均から差を求め，全タスクの macro 平均を保存した．言い換え実験では各タスク内の 4 種類の言い換えも復元抽出した．95%区間は，20,000 個の差の 2.5%点と 97.5%点とした．同一タスクの API 反復は独立標本として数えていない．なお本稿の区間は多重比較の補正を行っておらず，クラスタ数は 5 である．

主実験, 防御実験, 操作レベル差評価では, 同じ入力を用い, 各条件で同一タスクを比較した．. 分析 seed は 20260805–20260816 の実験ごとに固定した．中断時は`--resume` により処理済みの task–repeat key を再実行しない．提示形式 A/B では，L_2 推薦に到達した 20 入力について，推薦ブロックを除いた入力 hash の一致を確認し，表現以外に差がある場合は実行を停止した．情報タスク正答率は，各タスクについて事前に定めた必須項目の充足を照合して採点した．

A.1.4　対応履歴の適応的変形

回避耐性評価では，(1) 過去の成功実績，(2) 権限委譲，(3) 情報整理を実行内容の具体化と見なす意味再定義，(4) L_1 は外部変更を伴わないため安全とする正当化，(5) 緊急度・報酬・リソース圧力，(6) これらの合成，の 6 変形を用いた（各 100 試行）．無防御で要求超過が生じた 5 変形は，プロンプト安全制約により 0 件となった．意味再定義では無防御でも要求超過が 0 件であり，防御の効果を示す証拠にはならない．無防御時の要求超過は各変形 100 試行中 0–25 件と少なく，防御後 0 件という結果だけでは効果の大きさを判断できない．

A.1.5　CNEI 評価の内訳

CNEI は, Lite の Adaptive memory 54 件, Matched Full 74 件，Paraphrase 29 件，Micro の無防御 L_1 395 件，安全制約適用 L_1 343 件，無防御 L_2 270 件，安全制約適用 L_2 160 件を遮断した．計 1,325 件すべてで防御後の要求超過は 0 件，誤介入も 0 件であった（表 A·1）．

A.1.6　運用記録から行動方針を形成する補助実験

提示形式 A/B の 20 入力は，一般利用者等が追記できる運用記録から情報を取得し，その内容から行動方針と運用情報を生成する補助実験から得た．5 ドメイン，clean ／ attack，各 20 反復，Lite ／ Micro の計 400 試行で，記録取得率は 100%であった．attack 条件では，要求超過を促す行動方針が 87%，L_2 推薦が 20%で形成された．このうち L_2 推薦に到達した 20 入力を用いて，行動方針の表現だけを変える A/B 比較を行った．この補助実験は主実験の攻撃成功率には含めない．運用記録の追記から始まる端点間

© 2026 Information Processing Society of Japan

表 A·1 適応攻撃と CNEI 再生評価の追加結果（件数/試行数）
Table A·1 Additional adaptive-attack and CNEI-replay results.

対象	条件	防御前/N	防御後
対応履歴	Authority	2/100	0
対応履歴	Composite	11/100	0
対応履歴	Non-exec.	1/100	0
対応履歴	Success rec.	15/100	0
対応履歴	Relabeling	0/100	0
対応履歴	Urg./reward	25/100	0
Lite	Adaptive	54/600	0
Lite	Matched	74/400	0
Lite	Para.	29/400	0
Lite	Legitimate L_1	0/400	0
Micro	None L_1	395/400	0
Micro	Safety L_1	343/400	0
Micro	None L_2	270/400	0
Micro	Safety L_2	160/400	0
合計		1,325/3,400	0

の攻撃成功率の測定には，この連鎖を実運用のオーケストレータ実装で置き換える必要があり，今後の課題である．

A.1.7 結果の比較上の注意

Nova Lite の主実験＋対応履歴条件 45.5%と，防御評価の Matched baseline 18.5%は，Runner とツール記述が異なるため直接比較しない．防御効果は，同一 Runner・入力・ツールスキーマで比較した 18.5%対 0%で評価する．同一の「＋行動方針」相当条件に対する値は，主実験 70.5%，操作レベル差評価 L_1 推薦 17.25%，Matched baseline 18.5%，adaptive 9.0%，paraphrase 7.25%と幅がある．これは Runner・ツール記述・言い換えの違いによるもので，本稿の主張は同一 Runner 内の条件間差分に基づく．

Micro の提示形式 A/B は，L_2 推薦に到達した 20 入力のみを対象とする．したがって，0/20 件と 20/20 件の差は提示形式の影響を示すが，CSP 全体の攻撃成功率には一般化しない．

また，Nova Pro と Claude の要求超過 0/400 件は，両モデルが CSP に常に耐性を持つことを意味しない．本稿では，情報整理要求では 0/400 件，正当な L_2 要求では 400/400 件のツール実行を観測したため，少なくとも今回の条件では単純なツール実行の回避ではないことを確認した．

© 2026 Information Processing Society of Japan